12/15/2025
Revised 12/15/2025

OPR: WVOT Cybersecurity

COMPLIANCE WITH THIS PUBLICATION IS MANDATORY

Publications are available online at
https://sites.google.com/wv.gov/othub/policy-governance/ot-policies

Questions and change recommendations related to this publication shall be directed to this publication's Office of Primary Responsibility (OPR). This policy shall be reviewed every two years to ensure continued alignment with current legal, operational, and strategic requirements. Revisions will be undertaken as necessary.

SUMMARY OF VERSIONS AND CHANGES

Version	Date	Revision Description
1.0	12/15/2025	New Policy

1. PURPOSE

1.1. This policy establishes standardized requirements and expectations to ensure that supply chain risks are appropriately identified, assessed, and managed to limit harm or consequences from supply chain-related events.

2. SCOPE

2.1. This policy applies to all departments (including agencies, boards, authorities, and commissions) within the Executive Branch of WV State Government, excluding constitutional officers, the WV Board of Education, the WV Department of Education, and the county boards of education that have access to or use State-provided resources. However, the WVOT recommends that all agencies, including those excluded above, follow this policy.

2.2. Where there are policies in place which provide less restrictions or security than this policy, those policies will be superseded by this policy. In instances where existing state and federal laws, regulations, and policies are more restrictive than this policy, the more restrictive provisions will prevail.

3. POLICY

3.1. SECURITY CONTROLS

3.1.1. This policy has been mapped to the applicable standard and the standard tags are contained in the procedure's metadata and listed here.

3.1.1.1. NIST SP 800-53 Rev. 5 Controls:

3.1.1.1.1. SR Supply Chain Risk Management (SCRM)

3.2. ROLES AND RESPONSIBILITIES

3.2.1. Agencies shall employ processes and procedures to protect against supply chain risks to systems, system components, or system services and to limit the harm or consequences from supply chain-related events. Information systems (including system components that compose those systems) need to be protected throughout the system development life cycle (i.e., during design, development, manufacturing, packaging, assembly, distribution, system integration, operations, maintenance, and retirement).

3.2.1.1. NIST SP 800-53 Rev. 5 Controls: SR-01

3.2.2. Agencies will develop a plan for managing supply chain risks associated with the research and development, design, manufacturing, acquisition, delivery, integration, operations and maintenance, and disposal of Agency systems, system components or system services.

3.3. SUPPLY CHAIN RISK MANAGEMENT PLAN

3.3.1. The dependence on products, systems, and services from external providers, as well as the nature of the relationships with those providers, present an increasing level of risk to the State. Threat actions that may increase security or privacy risks include unauthorized production, the insertion or use of counterfeits, tampering, theft, insertion of malicious software and hardware, and poor manufacturing and development practices in the supply chain. Supply chain risks can be endemic or systemic within a system element or component, a system, an Organization, a sector, or the Nation.

3.3.2. Agencies shall:

3.3.2.1. Review and update the supply chain risk management plan as required, to address threat, organizational, or environmental changes.

3.3.2.2. Protect the supply chain risk management plan from unauthorized disclosure and modification.

3.3.2.3. Establish a supply chain risk management team consisting of information technology, security, privacy, legal, and procurement Personnel who lead and support acquisition and procurement activities.

3.3.3. Managing supply chain risk is a complex, multifaceted undertaking that requires a coordinated effort across all Agencies to build trust relationships and communicate with internal and external stakeholders. Supply chain risk management (SCRM) activities include identifying and assessing risks, determining appropriate risk response actions, developing SCRM plans to document response actions, and monitoring performance against plans. The SCRM plan (at the system-level) is implementation specific, providing policy implementation, requirements, constraints, and implications. In the absence of a sustainable and executable specific SCRM plan, the State shall use the Risk Assessment Procedures to inform risk-based decisions on supply chain risk.

3.3.4. NIST SP 800-53 Rev. 5 Controls: SR-02

3.4. SUPPLY CHAIN CONTROLS AND PROCESSES

3.4.1. Agencies shall:

3.4.1.1. Establish processes and procedures to identify and address weaknesses or deficiencies in the supply chain elements including:

3.4.1.1.1. Hardware, software, and firmware development processes.

3.4.1.1.2. Shipping and handling procedures.

3.4.1.1.3. Personnel security and physical security programs.

3.4.2. Supply chain elements include Agencies, entities, or tools employed for the research and development, design, manufacturing, acquisition, delivery, integration, operations and maintenance, and disposal of systems and system components. Supply chain elements and processes may be provided by Organizations, system integrators, or external providers. Weaknesses or deficiencies in supply chain elements or processes represent potential vulnerabilities that can be exploited by adversaries to cause harm to the Organization and affect its ability to carry out its core missions or business functions. In the absence of a sustainable and executable specific SCRM plan, the State shall use the Risk Assessment Procedures to inform risk-based decisions on supply chain risk.

3.4.3. NIST SP 800-53 Rev. 5 Controls: SR-03

3.5. ACQUISITION STRATEGIES, TOOLS, AND METHODS

3.5.1. Agencies shall employ the following acquisition strategies, contract tools, and procurement methods to protect against, identify, and mitigate supply chain risks:

3.5.1.1. Adhere to all State and Federal laws, executive orders, circulars, policies, and guidelines pertaining to procurements of systems, system components, and/or services.

3.5.1.2. When feasible, obscure the end use of a system or system component.

3.5.1.3. Requiring tamper-evident packaging.

3.5.1.4. Using trusted or controlled distribution.

3.5.2. Agencies should contact the Office of Technology and/or the WV Purchasing Division for guidance regarding applicable State and Federal laws, executive orders, circulars, directives, regulations, policies, and guidelines governing the procurement of systems, system components, and services.

3.5.3. Tools and techniques may provide protections against unauthorized production, theft, tampering, insertion of counterfeits, insertion of malicious software or backdoors, and poor development practices throughout the system development life cycle.

3.5.4. NIST SP 800-53 Rev. 5 Controls: SR-05

3.6. SUPPLIER ASSESSMENTS AND REVIEWS

3.6.1. Agencies shall assess and review the supply chain-related risks associated with suppliers or contractors and the system, system component, or system service they provide:

3.6.1.1. Prior to contracting with a supplier.

3.6.1.2. At least annually thereafter.

3.6.1.3. In response to a supply chain incident involving the supplier.

3.6.1.4. Upon changes to the supplier’s organizational structure or environment.

3.6.2. An assessment and review of supplier risk includes security and supply chain risk management processes, foreign ownership, control, or influence (FOCI), and the ability of the supplier to effectively assess subordinate second-tier and third-tier suppliers and contractors.

3.6.3. Agencies can use open-source information to monitor for indications of stolen information, poor development and quality control practices, information spillage, or counterfeits.

3.6.4. Agencies should review the US Department of Commerce Bureau of Industry and Security Lists of Parties of Concern, the International Trade

Association Consolidated Screening List, and the National Defense Authorization Act (NDAA) Section 889 prior to contracting with a supplier. In general, Agencies should avoid purchasing systems, system components, and services from companies on these lists due to threats they pose to the State and/or Nation. Agencies should contact the WVOT for further guidance.

3.6.5. NIST SP 800-53 Rev. 5 Controls: SR-06

3.7. NOTIFICATION AGREEMENTS

3.7.1. WVOT shall establish agreements and procedures with entities involved in the system, system component, or system service supply chain requiring notification of supply chain compromises; results of assessments or audits; and remediation plans, as applicable.

3.7.2. The establishment of agreements and procedures facilitates communications among supply chain entities. Early notification of compromises and potential compromises in the supply chain that can potentially adversely affect or have adversely affected Agency systems or system components is essential for Organizations to effectively respond to such incidents. The results of assessments or audits may include open-source information that contributed to a decision or result and could be used to help the supply chain entity resolve a concern or improve its processes.

3.7.3. NIST SP 800-53 Rev. 5 Controls: SR-08

3.8. INSPECTION OF SYSTEMS OR COMPONENTS

3.8.1. Upon receipt of systems and/or systems components, the receiving Agency must inspect the packaging, bill of lading, packing slip, systems and/or system components for any signs of tampering with the system or systems components.

3.8.2. Agencies should develop processes to inspect systems and systems components any time the system or component is removed from Agency-controlled areas (e.g., system and components sent out for repair and returned to the Agency) and/or when Individuals return from travel to high-risk areas. Indications of a need for inspection include changes in packaging, specifications, factory location, or entity in which the part is purchased.

3.8.3. NIST SP 800-53 Rev. 5 Controls: SR-10

3.9. COMPONENT AUTHENTICITY

3.9.1. Agencies shall:

3.9.1.1. Not knowingly procure counterfeit systems or components.

3.9.1.2. Employ a risk-based approach to reduce the frequency and impact of counterfeit systems or system components within Agency acquisitions and Agency life-cycle sustainment processes by:

3.9.1.2.1. Applying prevention and early detection procedures to minimize the presence of counterfeit components within the Agency supply chain as the primary strategy in eliminating counterfeit materiel within the Agency.

3.9.1.2.2. Strengthening the oversight and surveillance procedures for critical and sensitive systems and system components;

3.9.1.2.3. Maintaining configuration control over system components awaiting service or repair and serviced or repaired components awaiting return to service.

3.9.1.3. Document all occurrences of suspect and confirmed counterfeit systems and system components.

3.9.1.4. Through the appropriate agency, investigate, analyze, and assess all cases of suspected counterfeit systems and systems components.

3.9.1.5. Notify Agency Management, the WVOT CISO, DHS, WV Privacy Office, and the source of the counterfeit component.

3.9.1.6. Provide awareness training to Agency Staff to include responsibilities and processes for inspection and reporting of suspected counterfeit systems and system components.

3.9.2. Sources of counterfeit components include manufacturers, developers, vendors, and contractors. Anticounterfeiting policies and procedures support tamper resistance and provide a level of protection against the introduction of malicious code.

3.9.3. NIST SP 800-53 Rev. 5 Controls: SR-11

4. POLICY SPECIFIC DEFINITIONS

4.1. National Institute of Standards and Technology (NIST) - The agency of the United States Department of Commerce whose mission is to promote U.S. innovation and industrial competitiveness by advancing measurement science, standards, and technology

4.2. Office of Primary Responsibility (OPR) - The primary section within WVOT that takes the lead on a specific policy or procedure. Usually the WVOT service provider/owner that the policy is related to or governs.

4.3. Supply chain risk management (SCRM) - the proactive process of identifying, assessing, and mitigating vulnerabilities to ensure the continuous flow of goods and services

4.4. West Virginia Office of Technology (WVOT) - The division of the Department of Administration established by WV Code § 5A-6-4a, et. seq., which is led by the State's CIO and designated to acquire, operate, and maintain the State's technology infrastructure. The WVOT is responsible for evaluating equipment and services, and reviewing information technology contracts.

5. RELEVANT MATERIALS AND DOCUMENTS

5.1. This policy is consistent with the following federal and state authorities

5.1.1. NIST CSF Identify – Business Environment (ID.BE), Protect – Awareness and Training (PR.AT), Identify – Governance (ID.GV), Identify – Supply Chain (ID.SC)

5.1.2. NIST SP 800-53 Rev. 5 Standard which can be found at: https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final.

5.1.3. IRS 1075 which can be found at: https://www.irs.gov/pub/irs-pdf/p1075.pdf

5.1.4. NHS0242 Systems and Services Acquisition Policy (SA)

5.1.5. International Trade Association Consolidated Screening List which can be found at: https://www.trade.gov/consolidated-screening-list

5.1.6. National Defense Authorization Act (NDAA) Section 889 which can be found at: https://www.acquisition.gov/Section-889-Policies

5.1.7. US Department of Commerce Bureau of Industry and Security Lists of Parties of Concern which can be found at: https://www.bis.doc.gov/index.php/12-policy-guidance/list-parties-of-concern

5.1.8. https://www.fcc.gov/supplychain/coveredlist